



OPTIM PEOPLE

**INFORME DE GAP ANALISYS
ESQUEMA NACIONAL DE SEGURIDAD (ENS)**

OPTIMPEOPLE, S.L

TAULA DE CONTINGUT

1	FITXA TÈCNICA	2
2	ANTECEDENTS	3
3	PROPOSTA DE CATEGORIZACIÓ	5
4	TROBALLES	8
4.1	Resum de compliment	8
4.2	Consideracions pel que fa al compliment dels requisits de l'ENS	12
5	CONCLUSIONS	22

1 FITXA TÈCNICA

Empresa	OPTIMPEOPLE, S.L.
Objecte	Diagnosticar el grau de compliment i implementació de les mesures establertes pel Reial decret 311/2022, de 3 de maig, pel qual es regula l'Esquema Nacional de Seguretat (ENS).
Abast proposat	"Els sistemes d'informació que donen suport als processos de consultoria estratègica i solucions de millora de processos amb IA."
Criteri de revisió	Es realitza l'avaluació d'acord amb un sistema de categoria MITJA després d'una valoració inicial de la possible categorització dels sistemes.
Dates de realització	05/05/2025 de 09:00 a 12:00 h 09/05/2025 de 09:00 a 14:00 h
Centres visitats	Revisió en remot
Equip auditor	Toni Ripoll. Consultor i auditor de SGSI
Representants entrevistats	Jordi Costa (CEO) Marc Muixí (IT)
Data de l'informe	23/05/2025

2 ANTECEDENTS

L'empresa:

L'empresa OptimPeople està constituïda per Jordi Roca com a soci únic, amb la col·laboració de Marc Muixí i Carlos Pérez com a freelances.

S'està en procés de creació de la societat OptimTech que seria la que aglutinaria els serveis de les solucions de millora de processos amb IA.

Actualment l'empresa no té cap sistema de gestió basat en una norma ISO.

Proposta de serveis:

De cara a aquest gap analysis es contemplen els serveis:

- Serveis de consultoria estratègica per al sector públic, tal com elaboració d'anàlisis i informes sectorials, plans estratègics, etc.
- Desenvolupament i operació de solucions IA per a la millora de processos en particular del sector públic, per exemple, per a facilitar la gestió d'expedients automatitzant els processos.

Es fa el desenvolupament, implantació i llicència de manteniment.

En general els serveis es presten a entitats del sector públic (diputacions, consells comarcals, ajuntaments, etc.), tot i que ocasionalment es dona servei a algun client privat, vinculat a la millora de processos.

Tecnologia

Per a la gestió interna de l'empresa (correu electrònic, documentació, etc.) es té contractat els serveis de Microsoft365.

Les solucions IA s'executen en entorns propis de Google o Microsoft, depenent de les eines que es necessiten, per exemple, del model d'IA a utilitzar. Es fan servir serveis PaaS, més que infraestructura de sistemes.

Cada projecte té la seva pròpia instància. Totes les entitats (p.ex. ajuntaments) d'un mateix projecte comparteixen instància. Dins de cada entitat, es pot fer la gestió de rols.

Es distingeixen:

- Usuaris interns que tenen accés centralitzat als entorns de Google i Microsoft.
- Usuaris externs: De les entitats, que tenen accés URL amb usuari/contrasenya. Actualment es fa una gestió manual.

Informació tractada:

- Serveis de consultoria: Documentació administrativa, documentació pública sectorial, informes anàlisis, dades estadístiques, ...

No es tracten dades personals

- Serveis solucions IA: Expedients (incloent dades de ciutadania i tercers, factures de tercers), sol·licituds que fa la ciutadania (per exemple, llicències d'obres), dades d'altres fonts externes públiques, lleis, decrets municipals, ...

Implica el tractament de dades personals sobre els ciutadans referits en expedients i sol·licituds.

El resultat és informació de suport que ha d'acabar sent revisada pels tècnics.

3 PROPOSTA DE CATEGORIZACIÓ

D'acord amb els criteris establerts en l'Annex 1 de l'ENS, així com la CCN-STIC 803 Guia de Seguretat de les TIC - Valoració dels Sistemes, es realitza la següent proposta de categorització, que hauria de ser revisada durant el procés d'implantació.

Motiu	Dimensió ¹	Nivell	Valoració
Disposició legal o administrativa	CIDAT	Segons requisits de clients	Genèricament per complir amb els requisits de l'Article 2.2 del ENS que estableix també s'aplica als sistemes d'informació de les entitats del sector privat presten serveis o proveeixin solucions a les entitats del sector públic per a l'exercici per aquestes de les seves competències i potestats administratives
Perjudici Directe al ciutadà	I	Baix	Perjudici a algun ciutadà, encara que esmenable. Un incident que afecti a la integritat de la informació no suposa un dany important, ja que la informació resultant sempre ha d'acabar essent revisada pels tècnics.
	C	Mitjà	Dany important, encara que esmenable. La divulgació d'informació dels expedients i sol·licituds dels ciutadans pot vulnerar els seus drets de privacitat, tot i que pel tipus d'informació no es considera que el dany sigui molt greu.
	D	Baix	Algun perjudici. La no disponibilitat de la informació, ja sigui per tramitar un expedient o sol·licitud, podria ocasionar algun perjudici als ciutadans, però que no seria greu en el marge d'1 a 5 dies.
	I	Baix	Pot ocasionar un incompliment formal d'alguna llei o regulació que afecti a les

¹ C: Confidencialitat; I: Integritat; D: Disponibilitat; A: Autenticitat; T: Traçabilitat

Incompliment d'una norma legal o administrativa			entitats clients, però seria fàcilment esmenable.
	C	Mitjà	Pot ocasionar un incompliment material d'alguna llei o regulació, o incompliment formal no esmenable. Un incident que afecti la confidencialitat podria suposar sancions greus en aplicació de la LOPDGDD.
	D	Baix	Incompliment formal lleu d'alguna llei o regulació, de caràcter esmenable Un retard en el lliurament d'informació requerida de traçabilitat, dins d'un marge entre 1 i 5 dies no seria greu.
	A	Baix	Incompliment formal lleu d'alguna llei o regulació, de caràcter esmenable Un problema d'autenticitat de la informació podria posar en qüestió els resultats del procés, malgrat que posteriorment hi ha una revisió pe part dels tècnics.
Incompliment d'una norma regulatòria	-	N/A	No s'identifica que pugi i9mploicar l'incompliment de normativa d'un reguladors.
Incompliment d'una norma contractual	CI	Mitjà	Incompliment formal o material d'una obligació contractual que s'hagi assumit en els contractes amb els clients.
	D	Baix	Incompliment formal lleu d'una obligació contractual S'estima que el marge d'indisponibilitat de la informació entre 1 i 5 dies no causaria un incompliment contractual greu.
Incompliment d'una norma interna	CIDAT	Baix	Pot ocasionar un incompliment formal d'alguna llei o regulació que afecti a les entitats clients, però seria fàcilment esmenable.
Pèrdues econòmiques	CI	Mitjà	Un incident en la pot suposar pèrdues econòmiques importants per al negoci (superiors al 4% i inferiors al 10% del pressupost anual de l'organització)

			Aquestes pèrdues econòmiques podrien ser el resultat de les sancions o penalitzacions que es poden produir, de la pèrdua d'ingressos producte de la pèrdua de contracte, o les despeses legals per respondre a possibles reclamacions.
Reputació	Totes	Mig	Un incident pot implicar un dany reputacional significatiu amb els ciutadans o amb altres entitats clients.
Protestes	Totes	Baix	No es preveu que un incident pugui desembocar en protestes o, si s'escau, protestes individuals sense alteració de l'ordre públic.
Delictes	I	Baix	Molt difícilment facilitaria la comissió de delictes, però podria dificultar la seva investigació si no es disposa de la informació necessària o aquesta no és correcta.
Dades personals	C	Mitjà	Si bé es tracten dades de categoria especial (salut) els riscos són moderats ja que no es tracten dades de categoria especial.
Disponibilitat dels serveis	D	Baix	S'estima un RTO d'entre 1 i 5 dies.

En resum, prenent el major nivell d'impacte per a totes les situacions, es recomana plantejar la implementació per acreditar el compliment del sistema en categoria **MITJA**.

4 TROBALLES

Aquesta és el detall de les troballes pel que fa a la situació actual de l'organització quant a la implantació de les mesures tècniques i organitzatives necessàries per disposar d'un sistema de categoria MITJA d'acord amb els requisits i els controls determinats per l'Esquema Nacional de Seguretat.

S'identifiquen principals punts forts, desviacions que requereixen obligatòriament dur a terme accions correctives, i oportunitats de millora que han de ser tingudes en compte per millorar-ne el compliment.

Per realitzar aquesta anàlisi s'han seguit els criteris d'auditoria establerts a la guia CCN-STIC-808 Verificació del Compliment (que es poden trobar en un document adjunt).

4.1 Resum de compliment

La següent taula resumeix el compliment estimat de les mesures actualment implementades, indicant amb un codi de colors el grau de compliment i el nivell d'esforç necessari per completar el requerit per l'ENS.

S'empren els següents nivells de compliment:

Nivell	Descripció
CORRECTE	Les mesures de l'ENS estan implantades i documentades en gran mesura Cal esperar que l'esforç addicional per assegurar el compliment sigui marginal.
ALT	Les mesures de l'ENS estan altament implantades, però parcialment documentades o cal implementar algunes millores lleus. Cal esperar que l'esforç addicional per assegurar el compliment sigui limitat.
MITJÀ	Les mesures de l'ENS estan parcialment implantades i/o escassament documentades Cal esperar que l'esforç addicional per assegurar el compliment sigui significatiu.
BAIX	Les mesures de l'ENS estan escassament implantades i documentades. Per a alguna de les mesures pot ser que l'esforç addicional per assegurar el compliment sigui considerable.
SC	Sense qualificar Mesures que és previsible que no estiguin implantades ja que típicament es preparen com a part del procés d'implantació.
n.a.	No aplica en l'àmbit determinat. Tot i que aplicaria per categoria o dimensions de seguretat, dins de l'àmbit no hi ha sistemes o recursos sobre els quals apliqui la mesura.

Per interpretar el quadre s'ha de tenir en compte que les mesures de seguretat són acumulatives d'acord amb l'increment de categoria del sistema, per la qual cosa, un incompliment per a una categoria més baixa repercuteix en el compliment de les categories superiors, encara que no existeixin mesures addicionals que s'incompleixen per a aquestes categories.

Les caselles en blanc corresponen a mesures de seguretat que no apliquen, ja sigui perquè no apliquen per la categoria del sistema o alguna de les seves dimensions de seguretat.

Mesures de seguretat		Categoria	
		BÀSICA	MEDIA
Articulat			
Art. 5	ITS i Guies de Seguretat	aplica	aplica
Art. 28	Declaració d'aplicabilitat	aplica	aplica
Art. 30	Perfils de compliment	n.a	n.a
Art. 32	Informe de l'Estat de la Seguretat	aplica	aplica
Art. 38	Procediments de Determinació de la Conformitat amb l'Esquema Nacional de Seguretat	aplica	aplica
Art. 40 Art. 41	Categorització dels sistemes d'informació	aplica	aplica
org	Marco organitzativo		
org.1	Política de seguretat	aplica	aplica
org.2	Normativa de seguretat	aplica	aplica
org.3	Procediments de seguretat	aplica	aplica
org.4	Procés d'autorització	aplica	aplica
op	Fita operativa		
op.pl	Planificació		
op.pl.1	Anàlisi de riscos	aplica	+ R1
op.pl.2	Arquitectura de Seguretat	aplica	+ R1
op.pl.3	Adquisició de nous components	aplica	aplica
op.pl.4	Dimensionament/gestió de la capacitat	aplica	+ R1
op.pl.5	Components certificats	n.a.	aplica
op.acc	Control d'accés		
op.acc.1	Identificació	aplica	+ R1
op.acc.2	Requisits d'accés	aplica	aplica

Mesures de seguretat		Categoria	
		BÀSICA	MEDIA
op.acc.3	Segregació de funcions i tasques	n.a.	aplica
op.acc.4	Procés de gestió de drets d'accés	aplica	aplica
op.acc.5	Mecanisme d'autenticació (usuaris externs)	+ [R1 o R2 o R3 o R4]	+ [R2 o R3 o R4] + R5
op.acc.6	Mecanisme d'autenticació (usuaris de l'organització)	+ [R1 o R2 o R3 o R4] + R8 + R9	+ [R1 o R2 o R3 o R4] + R5 + R8 + R9
op.exp	Explotació		
op.exp.1	Inventari d'actius	aplica	aplica
op.exp.2	Configuració de seguretat	aplica	aplica
op.exp.3	Gestió de la configuració de seguretat	aplica	+ R1
op.exp.4	Manteniment i actualitzacions de seguretat	aplica	+ R1
op.exp.5	Gestió de canvis	n.a.	aplica
op.exp.6	Protecció enfront de codi maliciós	aplica	+ R1 + R2
op.exp.7	Gestió d'incidents	aplica	+ R1 + R2
op.exp.8	Registre de l'activitat	aplica	+ R1 + R2 + R3 + R4
op.exp.9	Registre de la gestió d'incidents	aplica	aplica
op.exp.10	Protecció de claus criptogràfiques	aplica	+ R1
op.ext	Recursos externs		
op.ext.1	Contractació i acords de nivell de servei	n.a.	aplica
op.ext.2	Gestió diària	n.a.	aplica
op.ext.3	Protecció de la cadena de subministrament	n.a.	n.a.
op.ext.4	Interconnexió de sistemes	n.a.	aplica
op.nub	Serveis al núvol		
op.nub.1	Protecció de serveis al núvol	aplica	+ R1
op.cont	Continuïtat del servei		
op.cont.1	Anàlisi d'impacte	n.a.	aplica
op.cont.2	Pla de continuïtat	n.a.	n.a.
op.cont.3	Proves periòdiques	n.a.	n.a.
op.cont.4	Mitjans alternatius	n.a.	n.a.
op.mon	Monitoratge del sistema		
op.mon.1	Detecció d'intrusió	aplica	+ R1

Mesures de seguretat		Categoria	
		BÀSICA	MEDIA
op.mon.2	Sistema de mètriques	aplica	+ R1 + R2
op.mon.3	Vigilància	aplica	+ R1 + R2
mp	Mesures de protecció		
mp.if	Protecció de les instal·lacions i infraestructures		
mp.if.1	Àrees separades i amb control d'accés	aplica	aplica
mp.if.2	Identificació de les persones	aplica	aplica
mp.if.3	Condicionament dels locals	aplica	aplica
mp.if.4	Energia elèctrica	aplica	+ R1
mp.if.5	Protecció davant incendis	aplica	aplica
mp.if.6	Protecció davant inundacions	n.a.	aplica
mp.if.7	Registre d'entrada i sortida d'equipament	aplica	aplica
mp.per	Gestió del personal		
mp.per.1	Caracterització del lloc de treball	n.a.	aplica
mp.per.2	Deures i obligacions	aplica	+ R1
mp.per.3	Conscienciació	aplica	aplica
mp.per.4	Formació	aplica	aplica
mp.eq	Protecció dels equips		
mp.eq.1	Lloc de treball net	aplica	+ R1
mp.eq.2	Bloqueig de lloc de treball	n.a.	aplica
mp.eq.3	Protecció de dispositius portàtils	aplica	aplica
mp.eq.4	Altres dispositius connectats a la xarxa	n.a.	n.a.
mp.com	Protecció de les comunicacions		
mp.com.1	Perímetre segur	aplica	aplica
mp.com.2	Protecció de la confidencialitat	aplica	+ R1
mp.com.3	Protecció de la integritat i de l'autenticitat	aplica	+ R1 + R2
mp.com.4	Separació de fluxos d'informació a la xarxa	n.a.	+ [R1 o R2 o R3]
mp.si	Protecció dels suports d'informació		
mp.si.1	Marcatge de suports	n.a.	aplica
mp.si.2	Criptografia	n.a.	n.a.

Mesures de seguretat		Categoria	
		BÀSICA	MEDIA
mp.si.3	Custòdia	n.a.	n.a.
mp.si.4	Transport	n.a.	n.a.
mp.si.5	Esborrat i destrucció	n.a.	n.a.
mp.sw	Protecció de les aplicacions informàtiques		
mp.sw.1	Desenvolupament d'aplicacions	n.a.	+ R1 + R2 + R3 + R4
mp.sw.2	Acceptació i posada en servei	aplica	+R1
mp.info	Protecció de la informació		
mp.info.1	Dades personals	aplica	aplica
mp.info.2	Qualificació de la informació	n.a.	aplica
mp.info.3	Signatura electrònica	aplica	+ R1 + R2 + R3
mp.info.4	Segells de temps	n.a.	n.a.
mp.info.5	Neteja de documents	aplica	aplica
mp.info.6	Còpies de seguretat	aplica	+ R1
mp.s	Protecció dels serveis		
mp.s.1	Protecció del correu electrònic	n.a.	aplica
mp.s.2	Protecció de serveis i aplicacions web	+ [R1 o R2]	+ [R1 o R2]
mp.s.3	Protecció de la navegació web	aplica	aplica
mp.s.4	Protecció enfront de denegació de servei	n.a.	aplica

4.2 Consideracions pel que fa al compliment dels requisits de l'ENS

A continuació, s'identifiquen de forma resumida aquells aspectes relacionats amb la implementació de les mesures tècniques i organitzatives requerides per l'ENS, identificant deficiències i oportunitats de millora que requereixen accions per cobrir els requisits establerts.

El detall es pot trobar a l'annex de MESURES DE COMPLIMENT ENS-OPTIMPEOPLE², que s'adjunta amb aquest informe.

Cal destacar que en aquest apartat no es valoren aquells requisits que es dona per descomptat que no es compleixen ja que típicament es preparen com a part del procés d'implantació. No s'espera que estiguin implementades ja que són requisits formals molt específics de l'ENS.

Mesures de seguretat		Troballes
org	Marc organitzatiu	
org.1	Política de seguretat	Document a elaborar durant el procés d'implantació Pel que fa als rols o funcions de seguretat: ▪ Caldria elaborar les descripcions de lloc de treball en particular de les responsabilitats quant a seguretat de la informació. ▪ No s'ha definit el lloc de Responsable de Seguretat de la Informació ▪ Caldria documentar formalment les funcions dels rols de: - responsable de la Informació - responsable del servei - responsable de seguretat de la informació - responsable del sistema - responsable de protecció de dades ▪ S'haurien de formalitzar els nomenaments, per exemple, en el Comitè de Seguretat de la Informació ▪ S'haurà de constituir el Comitè de Seguretat de la Informació i formalitzar els nomenaments. Implica documentar formalment la composició, funcions, i periodicitat de reunions del Comitè.
org.2	Normativa de seguretat	Caldria elaborar una normativa de seguretat de la informació com a part del procés d'implantació.
org.3	Procediments de seguretat	Caldria documentar el procediments de treball
org.4	Procés d'autorització	Si bé com a procediment formal típicament es prepara com a part del procés d'implantació, existeixen diversos requisits que s'hauran de cobrir en altres mesures referenciades: seguretat física, gestió de canvis, normativa d'usuaris, gestió de proveïdors....

² Cal recordar que aquest annex s'ha elaborat a partir del model establert per la guia CCN-STIC-808 *Verificació de compliment de les mesures ENS* i, per tant, és totalment reaprofitable com a punt de partida per al procés d'implantació de l'ENS, actualitzant-lo amb la informació de les mesures que es vagin implementant.

Mesures de seguretat		Troballes
op	Marc operatiu	
op.pl	Planificació	
op.pl.1	Anàlisi de riscos	No es disposa de cap anàlisi de riscos, ni que sigui semiformal, que inclogui: - Identificació i valoració d'actius - Valoració d'impacte de les amenaces més probables - Valoració de l'efectivitat de les salvaguardes - Càlcul del risc residual S'haurà d'elaborar com a part del procés d'implantació
op.pl.2	Arquitectura de Seguretat	S'haurà de disposar de documentació/diagrames de les solucions. Actualment formen part de la documentació que es lliura amb cada projecte. També caldrà implementar els requisits mínims d'un sistema de gestió de la seguretat de la informació.
op.pl.3	Adquisició de nous components	S'haurà de preparar un procediment bàsic d'adquisició de serveis i components IT que tinguin en compte els aspectes relacionats amb la seguretat de la informació tal com: - Avaluació de riscos - Possible impacte - Adequació a l'arquitectura existent - Necessitats de formació i tècniques. En aquest cas es considera que l'impacte és baix atès que les compres de components són molt ocasionals.
op.pl.4	Dimensionament/gestió de la capacitat	Serveis en modalitat de pagament per us, Caldrà documentar el procés i tenir evidències de l'estudi de capacitat que es fa abans d'implementar noves solucions. També caldrà documentar els mecanismes per a portar el control de l'ús que se'n fa, per exemple de control de llindars (alertes).
op.pl.5	Components certificats	Seria part del procés d'implantació verificar la inclusió en el catàleg dels components de seguretat o documentar les verificacions realitzades com a mesura compensatòria. Tanmateix, els serveis de Google Cloud i Microsoft Azure en general disposen de certificació ENS de categoria ALTA.
op.acc	Control d'accés	
op.acc.1	Identificació	Tots els sistemes tenen un control d'accés implementat. Caldrà assegurar que tots els usuaris amb accés a les plataformes tecnològiques tenen un compte d'usuari únic, evitant entrar a fer tasques de configuració amb un compte d'usuari genèric d'administració.

Mesures de seguretat		Troballes
		S'hauria de documentar el procés d'alta i baixa d'usuaris mitjançant un procediment formal. També es recomana establir algun registre, per exemple, mitjançant una eina de ticketing, per mantenir la traçabilitat de les peticions i tasques realitzades.
op.acc.2	Requisits d'accés	S'haurà de documentar en el procés de gestió d'accessos els responsables dels diferents actius que han de determinar la política d'accés i realitzar les autoritzacions d'accés necessàries.
op.acc.3	Segregació de funcions i tasques	No s'identifica la necessitat d'implantar millores rellevants, tot i que caldria veure situacions concretes que requereixin un procés d'autorització.
op.acc.4	Procés de gestió de drets d'accés	En les aplicacions hi ha una gestió de permisos i rols a nivell d'administració i d'usuaris. S'hauria de documentar la política d'accés amb els sistemes i privilegis als quals es pot accedir en funció del lloc de treball. Almenys anualment hauria de deixar evidència que s'han revisat els accessos a tots els sistemes.
op.acc.5	Mecanisme d'autenticació (usuaris externs)	Aplicaria als usuaris de les aplicacions (personal de les entitats client) Cal establir el model de responsabilitats especialment per a la petició i assignació de nous accessos, que hauria de recaure en el client. Addicionalment, les aplicacions haurien de permetre configurar, a petició del client: ▪ Canvi de la contrasenya periòdicament ▪ Limitació de reintents d'accés ▪ 2FA
op.acc.6	Mecanisme d'autenticació (usuaris de l'organització)	S'han de millorar alguns aspectes tals com: ▪ Assegurar que es disposa de l'acceptació de la normativa de seguretat abans d'activar els comptes d'usuari ▪ Revisar les polítiques de Google Cloud i Azure en quant a: - Limitació de número de reintents - Complexitat i longitud de contrasenyes - Polítiques de renovació de contrasenyes ▪ També caldrà veure si aquestes plataformes permeten: - Informar l'usuari de l'últim accés realitzat - Informar l'usuari de les seves obligacions després de tenir accés.
op.exp	Explotació	
op.exp.1	Inventari d'actius	No s'identifica la necessitat d'implantar millores rellevants.

Mesures de seguretat		Troballes
		Inventari en els propis serveis de Google Cloud i Azure
op.exp.2	Configuració de seguretat	S'hauria de poder evidenciar que s'han tingut en compte les bones pràctiques en la configuració dels serveis de Google Cloud i Azure Per exemple: https://www.ccn-cert.cni.es/es/pdf/guias/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/6206-ccn-stic-888b-guia-de-configuracion-segura-para-gcp/file.html
op.exp.3	Gestió de la configuració de seguretat	Es mantindria d'acord amb els procediments de gestió de canvis i gestió d'incidents.
op.exp.4	Manteniment i actualitzacions de seguretat	En general no aplica ja que estan a càrrec dels propis serveis de Google Cloud i Azure. Si que s'haurà de tenir en compte de verificar les configuracions si hi ha canvis en els models de IA, per exemple, canvis en les llibreries.
op.exp.5	Gestió de canvis	En general es comuniquen verbalment els canvis rellevants, sense evidències formals. Caldrà definir un procediment de gestió de canvis en els sistemes.
op.exp.6	Protecció enfront de codi maliciós	No s'identifica la necessitat d'implantar millores rellevants. S'haurà de justificar els antivirus dels equips de treball, incloent els MAC. A Windows de Jordi té el Norton 360.
op.exp.7	Gestió d'incidents	Caldrà disposar d'un procediment de gestió d'incidents que documenti un procés integral per fer front als incidents que puguin tenir un impacte en la seguretat del sistema, que inclogui l'informe d'esdeveniments de seguretat i debilitats, detallant els criteris de classificació i l'escalat de la notificació. Així mateix, s'haurà de contemplar la gestió completa dels incidents, així com les mesures per prevenir que es repeteixin els incidents.
op.exp.8	Registre de l'activitat	A nivell aplicacions: - Login derivat a un sistema d'autenticació de Google (Firebase) - Registre d'accions a l'aplicació existent. A nivell plataformes internes: - Propis de Google Cloud i Azure que s'haurien d'activar (audit trail) També caldrà documentar les polítiques que determinen quins registres s'activen, retenció, etc.

Mesures de seguretat		Troballes
op.exp.9	Registre de la gestió d'incidents	Lligat a la necessitat d'un procediment de gestió d'incidents, s'haurà de disposar d'un mecanisme per registrar els incidents, per exemple, mitjançant una eina de ticketing. Atès que a OPTIMPEOPLE els incidents són molt ocasionals, es pot també disposar d'un registre més informal.
op.exp.10	Protecció de claus criptogràfiques	Caldrà definir una política de controls criptogràfics que especifiqui els casos d'ús, la gestió del seu cicle de vida, la seva protecció, etc., per exemple en: - Claus autogestionades de Google KMS - Xifrat de base de dades Firebase S'haurà d'assegurar que s'empren algorismes i paràmetres autoritzats pel CCN.
op.ext	Recursos externs	
op.ext.1	Contractació i acords de nivell de servei	Caldrà localitzar la informació de SLAs dels serveis de Google Cloud i Azure que s'utilitzen. Els serveis de Google Cloud i Microsoft Azure en general disposen de certificació ENS de categoria ALTA
op.ext.2	Gestió diària	La revisió dels SLA dels proveïdors es podria incloure com a part de les tasques de supervisió del comitè trimestral.
op.ext.3	Protecció de la cadena de subministrament	n.a.
op.ext.4	Interconnexió de sistemes	Actualment no hi ha connexió amb altres sistemes del clients. El client carrega la informació. Es pot accedir informació pública (per exemple cadastral) Si que es publiquen APIS per tant, caldria que les serves característiques i mesures de seguretat quedin documentades com a part dels projectes.
op.nub	Serveis al núvol	
op.nub.1	Protecció de serveis al núvol	Estaria contempla en la configuració i validació de serveis de tercers. Talc com s'indica a la mesura op.exp.2, s'hauria de poder evidenciar que s'han tingut en compte les bones pràctiques en la configuració dels serveis de Google Cloud i Azure Per exemple: https://www.ccn-cert.cni.es/es/pdf/guias/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/6206-ccn-stic-888b-guia-de-configuracion-segura-para-gcp/file.html

Mesures de seguretat		Troballes
op.cont	Continuïtat del servei	
op.cont.1	Anàlisi d'impacte	S'haurà de fer l'estudi per documentar el BIA per determinar RTO, MTPD i RPO
op.cont.2	Pla de continuïtat	n.a.
op.cont.3	Proves periòdiques	n.a.
op.cont.4	Mitjans alternatius	n.a.
op.mon	Monitoratge del sistema	
op.mon.1	Detecció d'intrusió	Possiblement coberts pels serveis de Google Cloud i Azure. Només caldria verificar si es requereix alguna activació addicional.
op.mon.2	Sistema de mètriques	L'informe INES s'haurà de generar com a part del procés d'implantació.
op.mon.3	Vigilància	Aplicacions: - En base al sistema de recollida de logs. - Caldrà veure si cal activar algun servei de vigilància Sistemes: - Sistemes auditoria i logs del proveïdor (tipus Cloudwatch) - S'haurà de veure com s'aplica
mp	Mesures de protecció	
mp.if	Protecció de les instal·lacions i infraestructures	
mp.if.1	Àrees separades i amb control d'accés	En base a certificacions ENS de Google Cloud i Azure.
mp.if.2	Identificació de les persones	En base a certificacions ENS de Google Cloud i Azure.
mp.if.3	Condicionament dels locals	En base a certificacions ENS de Google Cloud i Azure.
mp.if.4	Energia elèctrica	En base a certificacions ENS de Google Cloud i Azure.
mp.if.5	Protecció davant incendis	En base a certificacions ENS de Google Cloud i Azure.
mp.if.6	Protecció davant inundacions	En base a certificacions ENS de Google Cloud i Azure.
mp.if.7	Registre d'entrada i sortida d'equipament	En base a certificacions ENS de Google Cloud i Azure.
mp.per	Gestió del personal	
mp.per.1	Caracterització del lloc de treball	(Lligat amb org.1) ▪ Caldria elaborar les descripcions de lloc de treball en particular de les responsabilitats quant a seguretat de la informació. ▪ Caldria documentar formalment les funcions dels rols de: - responsable de la Informació - responsable del servei

Mesures de seguretat		Troballes
		- responsable de seguretat de la informació - responsable del sistema - responsable de protecció de dades
mp.per.2	Deures i obligacions	(lligat amb org.2) Caldria elaborar una normativa de seguretat de la informació com a part del procés d'implantació.
mp.per.3	Conscienciació	No s'estan realitzant accions de conscienciació de forma sistemàtica. Ser recomana plantejar: - Accions periòdiques programades, per exemple, distribució d'articles o recordatoris de normativa - Accions puntuals en resposta a amenaces detectades (per exemple, alertes INCIBE o altres fonts)
mp.per.4	Formació	Actualment no ha realitzat formació específica en Seguretat de la Informació. Caldria poder acreditar la formació del personal que tracta la informació i els sistemes, amb formació adequada a les competències necessàries per al seu lloc de treball. D'entrada es documentaria com a formació les sessions de gap analysis. El repte serà documentar la autoformació
mp.eq	Protecció dels equips	
mp.eq.1	Lloc de treball net	A contemplar en la normativa de seguretat de la informació.
mp.eq.2	Bloqueig de lloc de treball	A contemplar en la normativa de seguretat de la informació l'obligació de bloquejar el terminal en absentar-se del lloc de treball. També s'hauria de configurar el bloqueig automàtic en tots els equips almenys transcorreguts 10 minuts d'inactivitat. Pot ser que s'hagi de poder especificar en les aplicacions el tancament automàtic de sessió per inactivitat.
mp.eq.3	Protecció de dispositius portàtils	A contemplar en la normativa de seguretat de la informació les mesures addicionals per a l'ús d'equips portàtils. S'hauria de verificar l'activació de: - Bitlocker a Windows - Filevault a Mac
mp.eq.4	Altres dispositius connectats a la xarxa	No aplica, no hi ha xarxa
mp.com	Protecció de les comunicacions	

Mesures de seguretat		Troballes
mp.com.1	Perímetre segur	En base a certificacions de Google Cloud i Azure
mp.com.2	Protecció de la confidencialitat	No aplica. No hi ha VPNs. Tot el tràfic per HTTPS
mp.com.3	Protecció de la integritat i de l'autenticitat	Connexions a Google Cloud i Microsoft Azure amb SSL amb 2FA.
mp.com.4	Separació de fluxos d'informació a la xarxa	En base a certificacions de Google Cloud i Azure
mp.si	Protecció dels suports d'informació	
mp.si.1	Marcatge de suports	No aplica. Per normativa es prohibeix el seu ús.
mp.si.2	Criptografia	No aplica, no hi ha suports
mp.si.3	Custòdia	No aplica, no hi ha suports
mp.si.4	Transport	No aplica, no hi ha suports
mp.si.5	Esborrat i destrucció	No aplica, no hi ha suports
mp.sw	Protecció de les aplicacions informàtiques	
mp.sw.1	Desenvolupament d'aplicacions	Es disposa d'entorns de desenvolupament i producció segregats en projectes diferents. En cas necessari es pot tenir entorn staging (preproducció). Es fa servir Github per protegir el codi. Caldria documentar la manera de treballar en un Cicle de Desenvolupament Segur, per exemple Agile/Scrum. Incloure la gestió de backlog, sprints, relació amb entregables,... Mecanismes d'identificació i autenticació integrada amb els propis serveis de Google. Si per alguna prova cal fer servir dades de producció, s'hauria de fer de forma controlada i documentada.
mp.sw.2	Acceptació i posada en servei	Caldrà documentar els processos de proves que es fan abans de posar un nou servei en producció.
mp.info	Protecció de la informació	
mp.info.1	Dades personals	No hi ha res implementat. Es signen els DPA que demana el client. Caldrà veure-ho en el projecte d'implementació.
mp.info.2	Qualificació de la informació	S'hauria de definir i aplicar una Política de Classificació de la informació per classificar i etiquetar la documentació
mp.info.3	Signatura electrònica	Certificats digitals per a la signatura de documents, factures, etc. Es fan servir certificats homologats.

Mesures de seguretat		Troballes
mp.info.4	Segells de temps	n.a.
mp.info.5	Neteja de documents	S'haurà d'incloure en la normativa de seguretat que s'han de verificar les metadades abans d'enviar, distribuir o publicar qualsevol document fora de l'organització. Igualment, s'haurien de verificar tots els documents (PDF) publicats al web i altres documents distribuïts a clients, usuaris,
mp.info.6	Còpies de seguretat	Caldrà documentar les polítiques de còpies de seguretat: ▪ Còpies de seguretat dins dels propis proveïdors, buckets, bases de dades, etc. per projectes. ▪ Documentació de codi font a github amb còpia local. ▪ Documentació d'empresa en Sharepoint o similars. Segons mesures de proveïdor.
mp.s	Protecció dels serveis	
mp.s.1	Protecció del correu electrònic	Sense necessitat de millores rellevants. Correu electrònic de Microsoft365, que va xifrat. Protegit amb les mesures de seguretat de Microsoft. Únicament seria convenient establir en la normativa limitacions a l'ús del correu electrònic com a suport de comunicacions privades
mp.s.2	Protecció de serveis i aplicacions web	S'hauria de documentar en l'arquitectura com es protegeix l'accés a les aplicacions. S'haurien d'executar anàlisis de vulnerabilitats de les aplicacions (ciixa negra), per exemple, ZAP Proxy. S'haurien d'executar anàlisis de vulnerabilitats del codi (caixa blanca), per exemple, SonarQube
mp.s.3	Protecció de la navegació web	S'haurà de contemplar en la normativa de seguretat de la informació. Caldrà veure si el Norton inclou filtres de navegació web. En el Mac hi ha funcionalitats
mp.s.4	Protecció enfront de denegació de servei	Contemplat pels serveis de Google Cloud i Microsoft Azure

5 CONCLUSIONS

Prenent en consideració els punts exposats en el punt anterior, com a conclusió general s'estima que OPTIMPEOPLE parteix d'un compliment molt baix de l'ENS i es requereix dur a terme un bon nombre d'accions de cara a obtenir el seu compliment.

Quant a la categorització del sistema, en base a l'avaluació proposada, queda clar que, com a mínim per a les dimensions de Confidencialitat i Integritat, el nivell de seguretat mínim requerit és MITJA, per la qual cosa la categoria del sistema haurà de ser MITJA, com a mínim. Això es deu principalment al fet que es tracten dades de ciutadans, que si bé no són de categoria especial, si que poden ser sensibles.

En conseqüència, s'ha realitzat una avaluació de compliment basant-nos en la necessitat de complir els requisits d'aquesta categoria MITJA.

Si bé, pel alt nombre de punts a millorar que s'han identificat es podria pensar que l'esforç és molt gran, cal considerar que:

- a) OPTIMPEOPLE té l'avantatge de que no gestiona una infraestructura TIC complexa, ja que es basa en l'ús de serveis de Google i Microsoft que molt probablement ja disposen de certificació de ENS en categoria ALTA.

En molts casos es tractarà de localitzar la documentació disponible per evidenciar que les mesures estan cobertes per aquests proveïdors.

- b) Moltes de les millores proposades es refereixen a aspectes documentals, ja sigui per documentar processos o disposar de millors evidències de compliment, per la qual cosa es poden implementar amb un esforç raonable i sense excessius costos.

En aquest aspecte, la col·laboració del servei d'assessorament serà essencial per tal d'agilitzar l'elaboració d'aquesta documentació.

- c) Si que hi ha algunes mesures que poden implicar la necessitat d'implementar millores en els sistemes o noves eines, per exemple, per al registre de logs i la seva supervisió, o la protecció de les aplicacions web, però aquests casos són molt puntuals.
- d) Si que caldrà contemplar com un projecte específic la implementació del compliment del RGPD i la LOPDGDD.
- e) Un dels àmbits on hi ha un menor compliment és en el de les mesures d'exploració (op.exp.*) ja que s'exigeix una major disciplina en tota la gestió i administració dels sistemes.
- f) Un altres àmbit en el que serà necessari treballar és en el d'incorporar a les aplicacions les funcionalitats necessàries per a que els clients puguin implementar les mesures necessàries per a demostrar el seu propi compliment, per exemple, en les funcions d'autenticació i gestió de registres.

En resum, si bé caldrà un esforç de l'organització i algunes inversions per millorar el compliment, es considera que el treball requerit pot ser assumible, amb els suport dels serveis d'assessorament, i plantejar-se l'obtenció de la certificació en menys d'un any.